Laporan Pengujian MediChain

Pemeriksaan lokal, MockChain, build frontend, dan tinjauan keamanan statis | 24 Oktober 2026

Ringkasan

Tes backend terisolasi, pemeriksaan TypeScript, dan build Next.js berhasil. File MockChain juga valid dan urutan nomor blok berurutan. Namun pemeriksaan ini tidak membuktikan aplikasi lengkap berjalan di Docker/PostgreSQL pada mesin pengguna: Docker daemon tidak dapat diakses dari sesi pemeriksaan. Tidak ada data aplikasi utama yang dibuat atau diubah.

Perkiraan status verifikasi lokal: 75%. Ini perkiraan keluasan bukti yang tersedia, bukan code coverage dan bukan jaminan bebas bug. Kesiapan migrasi Sepolia belum terverifikasi.

Hasil pemeriksaan

Area	Hasil	Batas
Backend/API	17 tes lulus; memakai SQLite dan MockChain terisolasi.	Bukan pengujian tulis terhadap PostgreSQL aplikasi aktif.
Frontend	TypeScript tanpa error; Next.js production build berhasil.	Tidak dilakukan uji klik/browser end-to-end.
MockChain	JSON valid; 4 rekam, 46 transaksi, 3 izin; blok berurutan.	Tidak membuktikan proses Docker aktif atau skenario multi-proses.
Konfigurasi	APP_ENV=development, CHAIN_MODE=mock, tamper simulation=false.	Nilai rahasia tidak ditampilkan dalam laporan.
Docker	Compose syntax check lolos.	Runtime ps/build tidak dapat diuji: akses Docker API ditolak (named pipe).
Sepolia	Kode Web3 dan panduan migrasi tersedia.	Kontrak belum dikompilasi/deploy/dicoba; RPC, writer, saldo, transaksi belum diuji.

Tinjauan keamanan

Kontrol yang terlihat di kode: autentikasi JWT HS256 dengan issuer/expiry; password scrypt; role-based access; pembatasan percobaan login/registrasi; header keamanan; CORS berbasis allowlist; validasi input; konfigurasi production menolak JWT lemah dan tamper simulation; API dan DB tidak dipublikasikan langsung oleh Compose.

Tes yang relevan mencakup lockout login, pembatasan registrasi, validasi role, integritas rekam, audit chain, retry outbox, dan alur izin. Semua tercakup dalam tes yang lulus.

Perkiraan verifikasi kontrol keamanan dasar: 60%. Ini bukan skor keamanan sistem. Pemindai dependency/static-security (Bandit, pip-audit) tidak tersedia; tidak ada penetration test, fuzzing, atau uji terhadap layanan publik.

Temuan dan risiko yang perlu ditindaklanjuti

1. Belum ada bukti runtime full-stack: jalankan stack di mesin pemilik dan uji login, peran, rekam, integritas, permohonan, audit, serta restart.

2. Belum siap dinyatakan siap Sepolia: deploy kontrak yang benar, verifikasi ABI/writer, gunakan RPC dan wallet testnet khusus, jalankan dry-run anchor, lalu uji satu data sintetis.

3. Rate limiter berada di memori: proteksi tidak dibagi antar worker/replika dan reset ketika proses restart. Jika deployment multi-instance, pindahkan ke Redis/shared limiter.

4. Prototipe belum diaudit: kontrak dan aplikasi belum menjalani audit pihak ketiga. Jangan gunakan data medis nyata atau mainnet.

5. Tes menghasilkan 129 warning deprecation/peringatan library, tetapi tidak ada kegagalan. Jadwalkan pembaruan API waktu UTC dan dependensi sebelum rilis lebih luas.

Langkah lanjutan yang aman

1. Di mesin lokal, pastikan hanya data sintetis yang dipakai, lalu jalankan **docker compose up --build -d** dan cek **docker compose ps** serta log layanan.

2. Uji alur UI utama. Untuk pasien/dokter uji, gunakan database terpisah atau salinan disposable; jangan membuat lalu menghapus data uji dari database utama karena jejak audit/chain dapat tetap tertinggal.

3. Simpan backup sebelum migrasi. Ikuti SEPOLIA_SETUP.md; pastikan mode, chain ID 11155111, alamat kontrak hasil deploy, writer, saldo testnet, dan konfigurasi rahasia benar.

4. Jalankan **docker compose exec api python -m scripts.anchor_existing_records --dry-run**. Tinjau seluruh hasil dan biaya. Perintah anchor tanpa dry-run mengirim transaksi publik yang tidak dapat dihapus.

5. Setelah itu, uji satu pasien sintetis dan verifikasi hash/transaction hash di Sepolia Etherscan. Jangan anggap tes MockChain sebagai bukti transaksi Sepolia.

Catatan metode dan cakupan

Pemeriksaan dilakukan secara lokal dan baca-saja terhadap data aplikasi. Tes backend membuat database/MockChain sementara lewat fixtures tes. Build frontend menghasilkan artefak .next. Pemeriksaan Docker compose syntax berhasil, tetapi koneksi runtime ke Docker daemon ditolak oleh lingkungan pemeriksa. Tidak ada permintaan jaringan publik dan tidak ada transaksi blockchain yang dikirim.

Kesimpulan: komponen kode yang dapat diuji secara offline lulus; keseluruhan sistem belum teruji 100%. Persentase di atas mengukur kelengkapan bukti saat ini, bukan jaminan bahwa tidak ada bug atau kerentanan.